MalAgent

鸿蒙及跨生态恶意软件深度解构与检测系统

主讲人：周俊霖

目录

01 研究背景

02 研究挑战

03 核心技术

04 项目效果

研究背景

网络攻防的盾与矛：恶意软件仍持续不断的造成威胁网络空间

关键基础设施风险

2025年4 月 ，SAP 披露了 NetWeaver Visual Composer 中的一个严重**零日漏洞** （CVE-2025-31324）。该漏洞允许未经身份验证的远程代码执行，从而允许不良行为者上传 Web shell 并破坏系统。研究人员发现超过 581 个 NetWeaver 实例正在被积极利用，包括与**国家**相关的团体

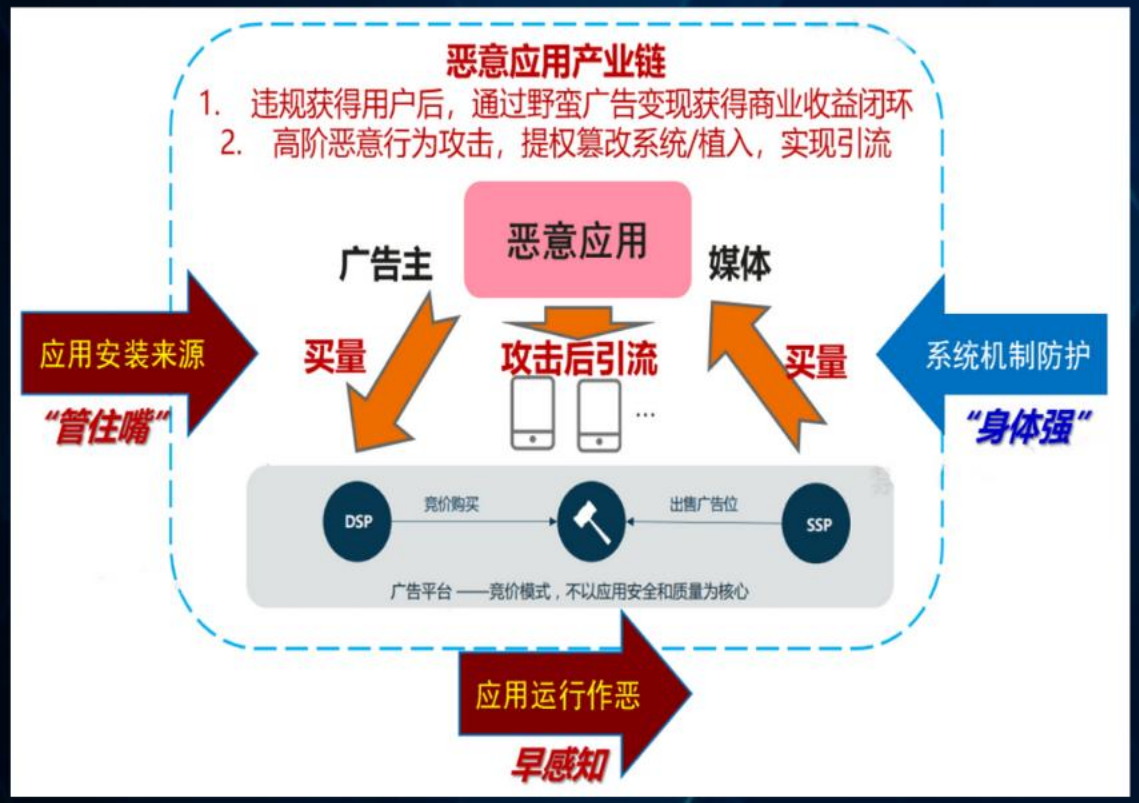
国家安全

2025年3 月，亲以黑客组织Predatory Sparrow入侵了伊朗的 Bank Sepah，窃取了惊人的 **4200 万**条客户记录（约 12 TB 数据），其中包括银行高级官员的详细信息。黑客威胁要支付 **4200 万**美元的比特币赎金

[1] 左图《Victor Golmer》来源： Getty Images　[2] 右图《ASHKAN FOROUZANI》来源：Cyber Security News

研究背景

鸿蒙应用生态构筑：新型业务面临新的挑战



未来鸿蒙应用生态，存在恶意应用检测一大难题

1. 鸿蒙生态应用使用ArKTS等语言开发，目前应用中的恶意行为和恶意代码的高水平检测是希望构筑的前瞻方向。
2. 不仅为生态应用保驾护航，同时提升鸿蒙生态下安全的用户体验和整体生态质量。

动态权限、内核分离的可信执行环境不是绝对安全

1. 新型业务安全，传统安全检测已无法满足生态安全的需要，如隐私泄露风险、广告应用泛滥难以防范。
2. 八成用户在受访过程表示存在无视风险，继续安装的情况。

[1] 图《鸿蒙恶意应用新型挑战示例》来源：华为 黄大年茶思屋 - [安全可信] 恶意应用代码检测及恶意攻击行为有效检出技术挑战

研究挑战 1 - 传统方法的局限性

·泛化能力差
·维护成本高

规则与模式匹配

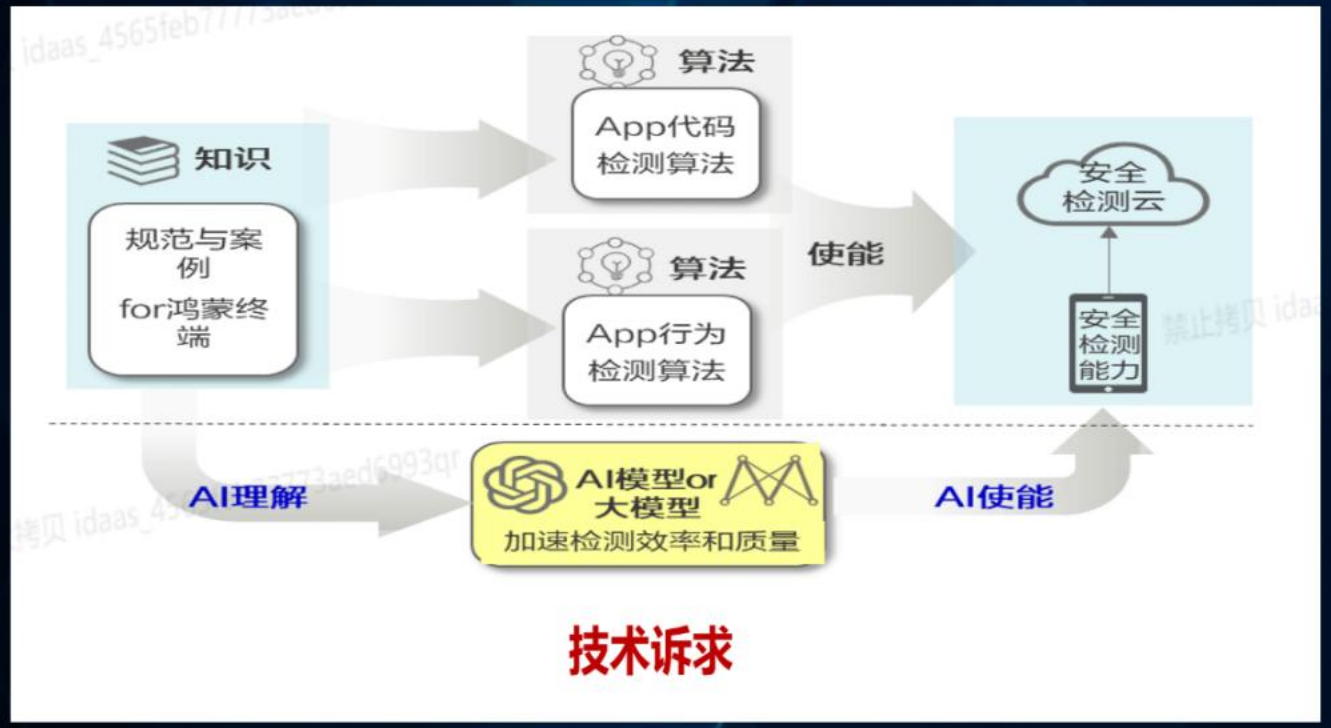
·易被混淆、规避
·缺乏行为识别能力

业界普遍采用，但检出率低

泛化能力弱，无法应对新型业务

运行时的行为检测能力参差不齐，无法支撑对恶意行为的提前检出

研究挑战 2 - AI方法缺乏专业知识



1

使用AI赋能系统在**底层代码、系统运行行为理解**具有一定分析能力，但缺乏直接获取这些信息的能力。

2

现有大模型缺乏对**HarmonyOS**以及**ArkTS**的知识的学习

↓

存在大量幻觉导致**大量误报**。

[1] 图《鸿蒙生态构筑技术诉求图》来源：华为 黄大年茶思屋 - [安全可信] 恶意应用代码检测及恶意攻击行为有效检出技术挑战

研究挑战 3 - 工具迁移性不强

工具与待解决问题之间存在
一一对应关系

企业角度而言，期待
能有**快速迁移的方法和工具**

用户角度而言，期待
能有**端到端的简易操作方案**

创新性说明

——创新方案

传统恶意软件检测系统	MalAgent
存在漏报、无法应对新型威胁	Multi-Agent双环驱动的AI赋能
模型幻觉、缺乏专业知识	人工标注数据集训练专有模型
扩展性不强，迁移困难	AI驱动端到端工具链 兼容多种文件、系统

核心技术 - 系统概览

APK
ETS
EXE
ELF
文件上传
是否解耦
是
JOERN
构建CPG
否
其他特征
MalAgent
文件多维度解构
专有大模型
Mutil-Agent
多引擎串联
检测报告

核心技术 1 - 文件多维度解构

Stage1：
处理初始文件输入
尽可能定位有效片段

文件解包

关键文件定位

文件类型识别

壳识别

已知

自定义脚本解析
eg.花指令

启发式数据流
跟踪定位有效片段

未知

MOBSF

提取其他特征

Stage2：
反编译各类Binary
尽可能获得源码表示

切片

Target
addr 6

```
source code:
.....
/*block at addr1*/
   printf("Enter the length ");
   read(0, &input_len, 4);
.....
```

地址对齐

```
source code:
.....
/*block at addr1*/
.....
/*block at addr3*/
.....
/*block at addr6*/
```

核心技术 2 - MalAgent专有知识模型

现有模型

专有知识缺乏

存在幻觉

误报率 **高**

人工标注1000+条对答数据

涵盖HarmonyOS、恶意软件专有知识

专有领域定制

符合实际

可靠性 **强**

专有模型

恶意样本

标注

对抗能力 — 加壳、混淆样本 — 100条

+

基础理解 — 多平台覆盖 EXE、ELF、APK、HAP — 各平台各100条

+

识别能力 — 常见恶意软件家族 — 10个常见家族150条

+

Harmony特有知识 — HarmonyOS、ArkTS特有知识 — 500+条

良性样本 — 包含来自各平台的正常应用和系统文件 — *350条*

人工构造问答微调数据集

Qwen2.5-16B

基于 QLoRA的SFT微调

[1]使用开源框架：LlamaFactory: Unified Efficient Fine-Tuning of 100+ Language Models

核心技术 3 - Multi-Agent双环检测

核心技术 4 - 多生态SOTA工具

反编译器

IDA Pro

GHidra

.abcD 反编译器

LLM4Decompile

脱壳工具

OllyDbg

PEiD

UPX

yodas

自制工具

文件解混淆

脱壳工具

JoernQueryTools

串联模型/引擎

VirusTotal

Dr.Web

Windows Defender

ConvNet

kaspersky

MalConv

[1] IDA Pro7.7：已取得正版授权

效果展示 1 - 平台对比

工具/检测引擎	支持生态	解决方案	AI 赋能	可解释性
微步	Windows、Linux	多引擎扫描、行为分析、图谱关系分析	部分、辅助生成报告	部分、对结果进行建议
VirusTotal	Windows、Linux macOS、Andorid	多引擎联合扫描 + Cuckoo 等沙箱分析	否	静态特征
HarmonyOS Safety Detect	HarmonyOS	运行时与安装时安全检测	否	否
MalAgent	Windows、Linux、Andorid HarmonyOS	LLM辅助+静态分析混合分析	是，AI驱动全流程	是，代码级别的解释

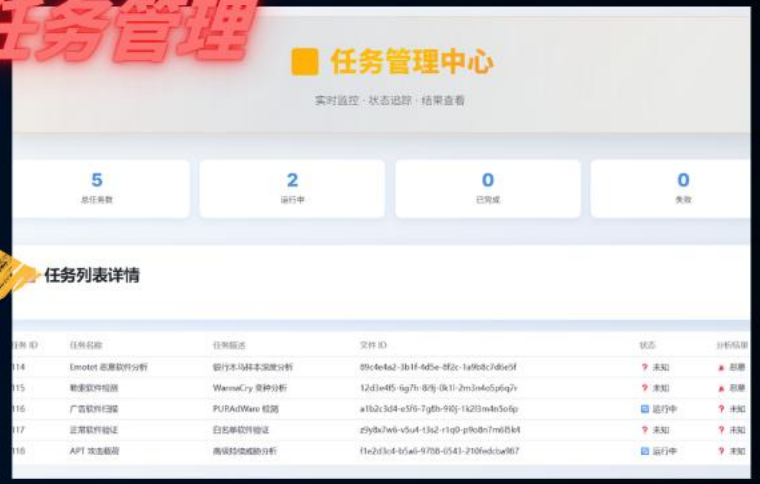
方法扩展性高 **AI驱动全流程** **文件深度解耦** **结果可靠性高**

效果展示 2 - 前端界面

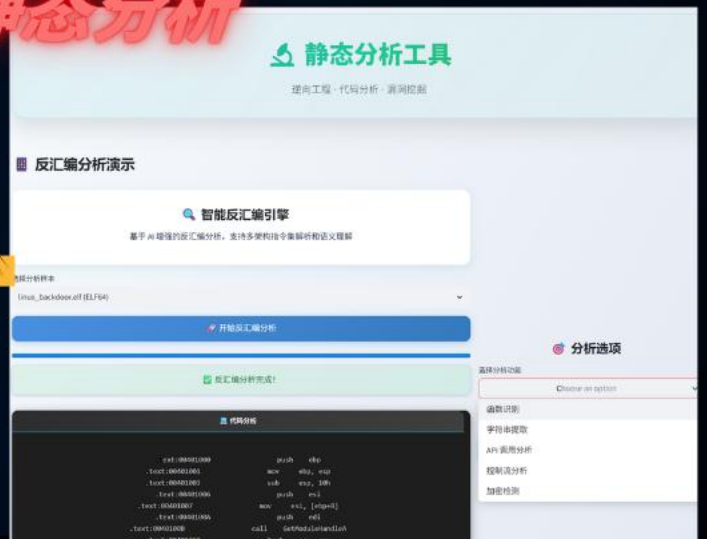
功能介绍

文件上传

任务管理



静态分析



智能脱壳

检测报告

效果展示 3 - HAP文件解构

```
// Class: com.opensource.microcourse/entry/ets/ControlDatabas
// Method: #~@0>@3**#
function #~@0>@3**#(FunctionObject, NewTarget, this, arg0){
  v0 = FunctionObject;
  v1 = NewTarget;
  v2 = this;
  v3 = arg0;
  v6 = AtkTsGlobal.Array;
  _acc_ = new v6();
  v4 = _acc_;
  while(true){
    v7 = v3;
    _acc_ = v7;
    _acc_ = _acc_.goToNextRow;
    v6 = _acc_;
    _acc_ = v6;
    _acc_ = v7._acc_();
    _acc_ = _acc_ == false;
    if(_acc_ != 0){
      break;
    }
    v8 = v3;
    _acc_ = v8;
    _acc_ = _acc_.getString;
    v7 = _acc_;
    v9 = 1;
    _acc_ = v7;
```

文件解构

```
getTimeName(p1) {
  var x_2_1 = new relationalStore_.RdbPredicates('TimeName');
  x_2_1.equalTo('ID', p1);
  return new Promise(function (p1, p2) {
    var x_3_1, x_3_2;
    x_3_1 = p1;
    x_3_2 = p2;
    x_1_1.rdbStore.query(x_2_1).then(function (p1) {
      const r1 = new Array();
      while (true) {
        if (!p1.goToNextRow()) {
          x_3_1(r1[0]);
          return undefined;
        } else {
          r1.push(p1.getString(1));
        }
      }
    }).catch(function (p1) {
      x_3_2(p1);
      return undefined;
    });
    return undefined;
  });
}
```

[1] 左图 开源工具：https://github.com/ohos-decompiler/abc-decompiler/releases

[2] 样本：Micro.Course.Signed.V1.1.hap 类：com.opensource.microcourse/entry/ets/ControlDatabase

效果展示 4 - 未知恶意软件检测对比

样本集	MalAgent	微步检测	Zero-shot + 人工代码
良性样本 * 100	14 / 100	10 / 100	47 / 100
恶意样本 * 100	85 / 100	88 / 100	67 / 100
HAP、ABC * 50	37 / 50	3 / 50	21 / 50
未知恶意文件 * 20	12 / 20	8 / 20	5 / 20

- 样本文件在数据集中采取标准抽样，每个结果最后由人工judge
- 未知恶意文件由人工编写
- Zero-shot+人工方法是指人工将伪代码构建prompt直接询问 GPT-4o统计得到结果

效果展示 5 - 最终交付物

微调大模型+训练数据集

- MalLLM（微调大模型）
- 1034条人工标注的训练数据集

源码+启动docker

- MalAgent系统前端、后端源码
- 一键启动docker

最终交付物

数据集

总计20332条恶意样本
总计18032 条良性样本
恶意样本有HAP人工制作200条+收集132条
良性样本有HAP人工制作200条+收集983条

其他物品

- 作品说明书
- 作品开发文档

感谢各位老师指正

主讲人：周俊霖